

THUYẾT MINH SÁNG KIẾN/GIẢI PHÁP

TÓM TẮT

Vấn đề. Điện thoại đã trở thành nơi lưu và trao đổi nhiều dữ liệu nội bộ phát sinh trong công tác và huấn luyện: giáo án, đề bài và đáp án thực hành, kết quả nghiên cứu chưa công bố, ảnh tư liệu. Các biện pháp sẵn có hoặc chỉ bảo vệ khi máy tắt, hoặc là phần mềm mã nguồn đóng không kiểm chứng được, hoặc là công cụ mạnh nhưng không có bản dùng được trên điện thoại.

Nguyên nhân kỹ thuật của khoảng trống. Các công cụ mật mã tin cậy hiện nay phần lớn được phân phối dưới dạng tệp nhị phân chạy độc lập. Hệ điều hành di động không cho ứng dụng sinh tiến trình con để chạy chúng, nên không thể chuyển thẳng sang điện thoại. Đây là rào cản thuộc về kiến trúc nền tảng, không phải vấn đề công sức lập trình.

Giải pháp của tác giả. Tác giả thiết kế một kiến trúc trong đó toàn bộ nghiệp vụ bảo vệ dữ liệu nằm trong một lõi độc lập với giao diện và với nền tảng, và đặt các điểm nối trùu tượng tại đúng những vị trí phụ thuộc nền tảng. Nhờ vậy, phần hiện thực bên dưới có thể thay bằng bản chạy trong tiến trình mà toàn bộ nghiệp vụ, định dạng dữ liệu và hành vi phía trên giữ nguyên. Tác giả tự thiết kế định dạng tệp kết, sơ đồ phân cấp khoá, quy tắc phân loại lỗi an toàn và tự viết mô-đun xử lý siêu dữ liệu.

Sản phẩm và bằng chứng. Sản phẩm là ứng dụng Android hoàn chỉnh với 38 chức năng nghiệp vụ, xây dựng trên 15 thành phần mã nguồn do tác giả tổ chức, kèm 272 hàm kiểm thử tự động. Tính tương thích định dạng được kiểm chứng bằng 5 phép thực nghiệm đối chứng với công cụ chuẩn, không phải bằng suy luận.

Giá trị. Sản phẩm vừa dùng được trong công tác để bảo vệ dữ liệu ngay trên thiết bị, vừa là học cụ trực quan cho giảng dạy an toàn thông tin: mỗi nhóm chức năng tương ứng một nguyên lý trong chương trình, và mã nguồn mở cho phép học viên đọc, chạy lại và phân tích một hệ thống an toàn thực tế.

MỤC LỤC

Nhấn chuột phải vào đây rồi chọn “Cập nhật trường” để hiện mục lục.

A. THÔNG TIN CHUNG

1. Tên sáng kiến/giải pháp: SecureVault Mobile — Ứng dụng bảo vệ dữ liệu nhạy cảm trên thiết bị Android hoạt động hoàn toàn ngoại tuyến, phục vụ công tác và huấn luyện an toàn thông tin

2. Thuộc lĩnh vực: An toàn thông tin trên không gian mạng; bảo vệ dữ liệu trên thiết bị di động; công nghệ thông tin phục vụ đào tạo – huấn luyện

3. Họ và tên tác giả:

.....

Năm sinh:

Tên cơ quan, đơn vị:

.....

Cấp bậc: **Chức vụ:**

Trình độ chuyên môn:

.....

Số điện thoại:

.....

B. NỘI DUNG CHÍNH CỦA SÁNG KIẾN/GIẢI PHÁP

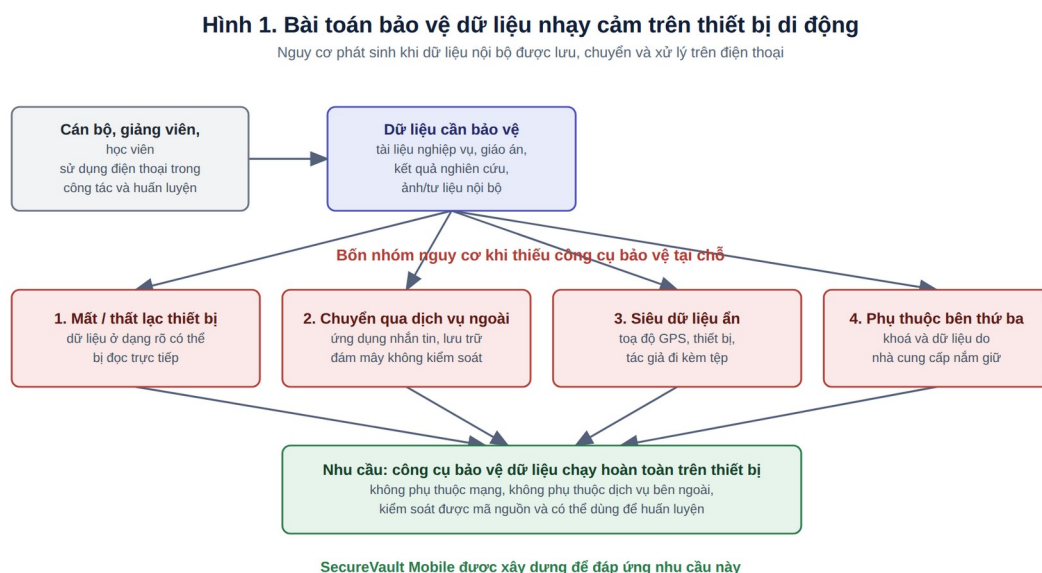
1. Hiện trạng giải pháp đã biết

1.1. Bối cảnh và nhu cầu thực tiễn

Điện thoại thông minh hiện là công cụ làm việc thường xuyên của cán bộ, giảng viên và học viên. Tính cơ động của thiết bị mang lại hiệu quả rõ rệt trong công tác, giảng dạy và nghiên cứu, nhưng đồng thời làm thay đổi căn bản phạm vi tồn tại của dữ liệu: nhiều tài liệu trước đây chỉ nằm trong máy tính cố định nay được sao chép, xem và trao đổi ngay trên thiết bị cá nhân.

Trong quá trình công tác và huấn luyện an toàn thông tin, thực tế phát sinh nhiều loại dữ liệu cần được bảo vệ ở mức cao hơn dữ liệu thông thường: giáo án và tài liệu biên soạn nội bộ, đề bài và đáp án các bài thực hành, kết quả nghiên cứu chưa công bố, ảnh và tư liệu phục vụ huấn luyện, dữ liệu trao đổi nghiệp vụ giữa các bộ phận. Việc lộ, lọt những dữ liệu này tuy không nhất thiết cấu thành sự cố ở mức cao nhất nhưng vẫn ảnh hưởng đến chất lượng công tác, tính khách quan trong đánh giá và uy tín của đơn vị.

Bốn nhóm nguy cơ nổi bật được trình bày ở Hình 1.



Hình 1. Bài toán bảo vệ dữ liệu nhạy cảm trên thiết bị di động

1.2. Các nhóm giải pháp đã biết và nhược điểm chưa được khắc phục

Tác giả đã khảo sát các nhóm giải pháp hiện có theo hướng tiếp cận chức năng nhằm xác định chính xác khoảng trống cần lấp. Phân tích dưới đây là khách quan: mỗi nhóm đều giải quyết tốt bài toán mà nó được thiết kế cho, vấn đề là không nhóm nào giải quyết trọn vẹn bài toán đang xét.

Bảng 1. So sánh các nhóm giải pháp đã biết với nhu cầu đặt ra

Nhóm giải pháp	Ưu điểm	Nhược điểm chưa được khắc phục
Mã hoá toàn thiết bị của hệ điều hành (FBE/FDE Android)	Bảo vệ dữ liệu khi thiết bị ở trạng thái tắt hoặc chưa mở khoá lần đầu; trong suốt với người dùng	Khi máy đã mở khoá, mọi ứng dụng và người cầm máy đều thấy dữ liệu ở dạng rõ; hoàn toàn không bảo vệ được tệp khi đưa ra khỏi thiết bị
Ứng dụng “khoá tệp”, “kết riêng tư” trên kho ứng dụng	Giao diện thuận tiện, cài đặt nhanh, nhiều lựa chọn	Phần lớn mã nguồn đóng nên không kiểm chứng được thuật toán và cách quản lý khoá; nhiều ứng dụng yêu cầu quyền truy cập mạng hoặc đồng bộ đám mây; định dạng riêng khiến người dùng bị khoá vào một sản phẩm
Trình quản lý mật khẩu mã nguồn mở (KeePassDX, Bitwarden...)	Quản lý thông tin đăng nhập rất tốt, kiểm chứng được	Được thiết kế cho mật khẩu, không nhằm xử lý tệp, ảnh, tài liệu và không có các nghiệp vụ ký số, kiểm tra toàn vẹn, chia khoá phục hồi, xử lý siêu dữ liệu
Công cụ mật mã dòng lệnh (age, GPG, OpenSSL, VeraCrypt)	Thuật toán tin cậy, được cộng đồng soi xét lâu dài	Không có bản dùng được trên di động do rào cản kiến trúc nền tảng (mục 3.b.2); giao diện dòng lệnh không phù hợp với người dùng không chuyên
Ứng dụng nhắn tin mã hoá đầu-cuối	Bảo vệ rất tốt dữ liệu trên đường truyền	Không bảo vệ dữ liệu ở trạng thái lưu trữ trên máy; dữ liệu vẫn đi qua hạ tầng của nhà cung cấp dịch vụ nước ngoài
Giải pháp quản lý thiết bị / chống thất thoát dữ liệu (MDM/DLP)	Quản lý tập trung, phù hợp quy mô lớn	Cần hạ tầng máy chủ, chi phí bản quyền và phụ thuộc nhà cung cấp; khó triển khai cho nhu cầu cá nhân và nhóm

		nhỏ
--	--	-----

Để so sánh khách quan hơn, bảng dưới đây đối chiếu theo từng tiêu chí kiểm tra được, thay vì nhận định định tính.

Bảng 2. Ma trận đối chiếu theo tiêu chí kiểm tra được

Tiêu chí	Mã hoá toàn thiết bị	Ứng dụng kết thương mại	Công cụ dòng lệnh	SecureVault Mobile
Chạy được trên Android	Có	Có	Không	Có
Không yêu cầu quyền mạng	Có	Thường không	Có	Có
Mã nguồn kiểm tra được	Một phần	Thường không	Có	Có
Có bộ kiểm thử công khai	Không rõ	Không	Có	Có
Bảo vệ tệp sau khi rời thiết bị	Không	Một phần	Có	Có
Ký số và kiểm tra nguồn gốc	Không	Hiếm	Có	Có
Chia khoá phục hồi theo ngưỡng	Không	Hiếm	Một phần	Có
Xử lý siêu dữ liệu ẩn trong ảnh	Không	Hiếm	Có	Có
Định dạng tệp theo chuẩn mở	Không áp dụng	Thường không	Có	Có
Dùng được làm học cụ giảng dạy	Hạn chế	Hạn chế	Có	Có

“Hiếm” nghĩa là có sản phẩm đáp ứng nhưng không phổ biến. Cột SecureVault Mobile đối chiếu với chức năng đã hiện thực và kiểm chứng, không phải chức năng dự kiến.

1.3. Khoảng trống mà sáng kiến hướng tới

Từ phân tích trên, khoảng trống được xác định là: chưa có công cụ đồng thời đáp ứng cả năm yêu cầu sau đây trên nền tảng Android.

- **Yêu cầu 1.** Hoạt động hoàn toàn trên thiết bị, không yêu cầu quyền truy cập mạng, không tài khoản, không đồng bộ đám mây.

- **Yêu cầu 2.** Mã nguồn kiểm soát được, thuật toán công khai, có bộ kiểm thử tự động để bên thứ ba có thể kiểm chứng lại.
- **Yêu cầu 3.** Gộp nhiều nghiệp vụ bảo vệ dữ liệu trong một ứng dụng thống nhất, thay vì phải dùng nhiều công cụ rời rạc.
- **Yêu cầu 4.** Tập tạo ra tương thích với chuẩn mở, không khoá người dùng vào một sản phẩm duy nhất.
- **Yêu cầu 5.** Đồng thời sử dụng được làm học cụ trực quan cho giảng dạy an toàn thông tin.

2. Mục đích của giải pháp

Sáng kiến nhằm xây dựng một ứng dụng Android giúp người dùng tự bảo vệ dữ liệu nhạy cảm ngay trên thiết bị của mình, đồng thời trở thành học cụ phục vụ giảng dạy và huấn luyện an toàn thông tin. Các mục tiêu cụ thể như sau.

- **Mục tiêu 1 – Bảo vệ dữ liệu tại chỗ:** Cung cấp cơ chế mã hoá, ký số, kiểm tra toàn vẹn, chia khoá phục hồi và xử lý siêu dữ liệu hoạt động hoàn toàn trên thiết bị, không phụ thuộc kết nối mạng hay dịch vụ bên ngoài.
- **Mục tiêu 2 – Bảo đảm chủ quyền dữ liệu:** Khoá và dữ liệu do người dùng nắm giữ hoàn toàn; ứng dụng không khai báo quyền truy cập mạng nên về mặt kỹ thuật không thể gửi dữ liệu ra ngoài.
- **Mục tiêu 3 – Kiểm chứng được:** Toàn bộ mã nguồn mở kèm 272 hàm kiểm thử tự động, cho phép kiểm tra lại các tuyên bố kỹ thuật thay vì phải tin vào lời khẳng định.
- **Mục tiêu 4 – Phục vụ đào tạo:** Mỗi nhóm chức năng tương ứng với một nguyên lý an toàn thông tin cụ thể, cho phép giảng viên minh hoạ trực quan và xây dựng bài thực hành có kết quả quan sát được ngay.
- **Mục tiêu 5 – Sử dụng được ngay:** Giao diện tiếng Việt, thao tác theo từng bước, thuật ngữ kỹ thuật đặt trong mục mở rộng để không gây quá tải cho người mới.

3. Mô tả giải pháp

a) Nguyên lý của giải pháp

Tác giả xây dựng giải pháp trên sáu nguyên lý do mình xác lập, chi phối toàn bộ thiết kế và được thể hiện trực tiếp trong mã nguồn. Các nguyên lý này không phải khẩu hiệu mà là ràng buộc kỹ thuật: mỗi nguyên lý đều có một cơ chế cụ thể bảo đảm nó được tuân thủ, và có kiểm thử tự động canh giữ.

Nguyên lý 1 – Ngoại tuyến tuyệt đối. Ứng dụng không có khả năng kết nối mạng. Không khai báo quyền truy cập mạng trong tệp kê khai — ràng buộc ở mức hệ điều hành, không phải lựa chọn cấu hình có thể thay đổi lúc chạy.

Nguyên lý 2 – Một lõi bảo vệ dữ liệu dùng chung. Toàn bộ nghiệp vụ mật mã tách khỏi giao diện và khỏi nền tảng. 15 thành phần độc lập, trong đó lõi không tham chiếu bất kỳ thư viện giao diện hay nền tảng nào; nhờ vậy phần dễ thay đổi không thể vô tình làm sai lệch phần cần ổn định.

Nguyên lý 3 – Phụ thuộc một chiều theo lớp. Lớp trên gọi lớp dưới, không có chiều ngược lại. Lõi phụ thuộc vào giao ước trừu tượng chứ không phụ thuộc bản hiện thực cụ thể, nên kiểm thử độc lập được và thay bản hiện thực không ảnh hưởng nghiệp vụ.

Nguyên lý 4 – Suy giảm an toàn khi thành phần không sẵn sàng. Không bao giờ chạy tiếp trong trạng thái không bảo đảm. Thành phần không sẵn sàng bị vô hiệu hoá và báo rõ ngay khi khởi động; định dạng ngoài phạm vi bị từ chối bằng lỗi có mã, không báo thành công giả.

Nguyên lý 5 – Thông báo lỗi không tạo kênh phân biệt. Không để kẻ tấn công dựa vào khác biệt thông báo mà suy đoán bí mật. Tác giả thiết kế quy tắc quy lỗi thống nhất: thất bại giải mã nội dung quy về “tệp hỏng” chứ không phải “sai xác thực”, vì tại thời điểm đó chữ ký ràng buộc và khoá đã được xác thực xong.

Nguyên lý 6 – Không lưu bí mật. Mật khẩu và khoá chính không bao giờ được ghi xuống bộ nhớ lưu trữ. Mật khẩu được bọc trong kiểu dữ liệu tự xoá khi hết phạm vi sử dụng; khoá chính chỉ tồn tại trong bộ nhớ phiên và bị xoá khi khoá kết.

Hình 2. Kiến trúc phân lớp của SecureVault Mobile (Android)

Sáu lớp, phụ thuộc một chiều từ trên xuống; lỗi mật mã không phụ thuộc giao diện



Vùng xanh = lỗi dùng chung, đã kiểm chứng bằng kiểm thử tự động; vùng cam = thành phần riêng cho di động

Hình 2. Kiến trúc phân lớp của SecureVault Mobile do tác giả thiết kế

b) Các nội dung chủ yếu

b.1. Kiến trúc tổng thể do tác giả thiết kế

Ứng dụng gồm sáu lớp (Hình 2). Điểm cốt lõi trong thiết kế là ranh giới giữa lớp bề mặt lệnh và lớp nghiệp vụ: toàn bộ giao tiếp giữa giao diện và lõi đi qua đúng 38 lệnh có kiểm soát, không có đường tắt. Mọi mật khẩu đi qua ranh giới này đều được bọc trong kiểu dữ liệu tự xoá, và phiên làm việc chỉ được tham chiếu bằng một mã định danh mờ — mã này không mang thông tin bí mật nên kể cả khi lộ cũng không dùng để suy ra khoá.

Cách tổ chức này là lựa chọn thiết kế có chủ đích: nó cho phép thay đổi hoàn toàn giao diện, hoặc thay đổi nền tảng chạy, mà không phải sửa một dòng nào trong phần nghiệp vụ mật mã — điều kiện tiên quyết để một lõi phục vụ được nhiều nền tảng.

b.2. Rào cản kiến trúc của nền tảng di động và cách tác giả vượt qua

Đây là nội dung mang hàm lượng kỹ thuật cao nhất của sáng kiến, và cũng là lý do các công cụ mật mã mạnh hiện nay không có bản dùng được trên điện thoại.

Vấn đề. Các công cụ mật mã tin cậy được phân phối dưới dạng tệp nhị phân chạy độc lập. Trên máy tính để bàn, ứng dụng gọi chúng như một tiến trình con. Trên thiết bị di động thì không: hệ điều hành iOS cấm hoàn toàn việc sinh tiến trình, còn Android chặn thực thi tệp nhị phân nằm trong vùng lưu trữ mà ứng dụng ghi được. Hệ quả là mọi chức năng phụ thuộc tiến trình con sẽ không hoạt động, kể cả khi mã nguồn biên dịch thành công — một cái bẫy nguy hiểm vì lỗi chỉ lộ ra khi chạy thật trên máy.

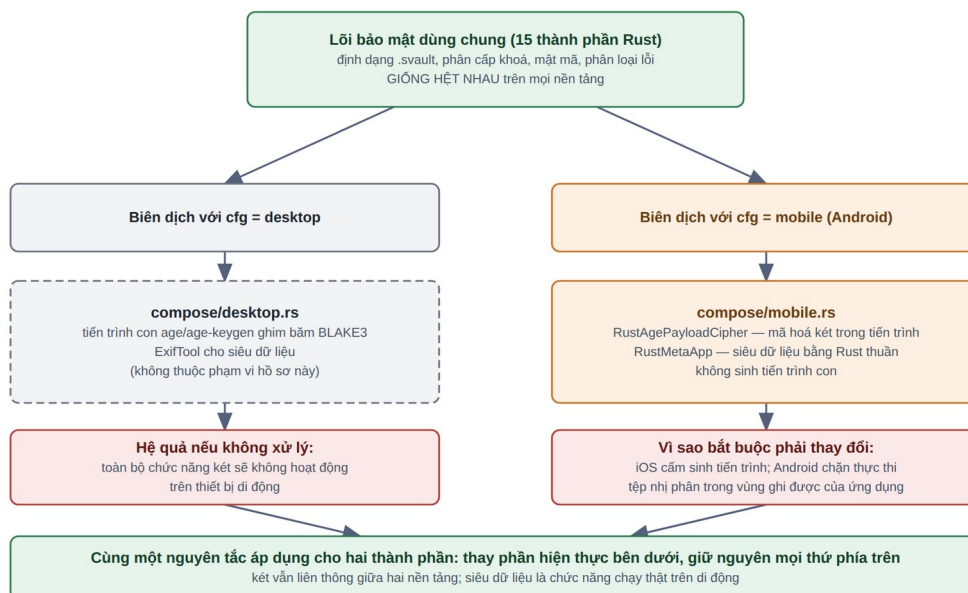
Cách giải quyết của tác giả. Thay vì viết lại ứng dụng riêng cho di động — cách làm dẫn tới hai bản mã nguồn phải đồng bộ thủ công và sớm muộn sẽ lệch nhau — tác giả đặt **điểm nối trừu tượng** tại đúng những vị trí phụ thuộc nền tảng, rồi thay phần hiện thực bên dưới bằng bản chạy trong tiến trình. Nguyên tắc này được áp dụng cho cả hai thành phần vướng rào cản:

- **Thành phần 1 — mã hoá nội dung kết:** tác giả tự hiện thực bộ mã hoá nội dung kết chạy trong tiến trình, giữ nguyên định dạng tệp đã thiết kế. Nhờ vậy kết tạo trên máy tính mở được trên điện thoại và ngược lại — tính chất này không hiển nhiên và đã được kiểm chứng bằng thực nghiệm.
- **Thành phần 2 — xử lý siêu dữ liệu:** ExifTool là chương trình viết bằng Perl, Android không có trình thông dịch Perl nên không có cách nào chạy được. Tác giả viết mới hoàn toàn mô-đun này bằng ngôn ngữ Rust, hiện thực ba nghiệp vụ xem,

xoá và so sánh siêu dữ liệu, chạy ngay trong tiến trình ứng dụng. Đây là chức năng có thật trên thiết bị, không phải trạng thái vô hiệu hoá.

Hình 3. Một lỗi bảo mật, hai gốc hợp thành theo nền tảng

Rào cản kỹ thuật và cách giải quyết đã được kiểm chứng bằng thực nghiệm



Hình 3. Nguyên tắc một lỗi dùng chung với hai gốc hợp thành theo nền tảng

Vì sao tính tương thích định dạng là điều kiện bắt buộc. Một giải pháp thay bộ mã hoá mà làm đổi định dạng tệp sẽ khiến dữ liệu cũ không mở được và người dùng bị khoá vào một phiên bản. Do đó tác giả xác định đây không phải chi tiết kỹ thuật phụ mà là ràng buộc thiết kế, và đã kiểm chứng bằng thực nghiệm đối chứng chứ không bằng suy luận.

Bảng 3. Kiểm chứng tương thích định dạng giữa hai bản hiện thực

Phép kiểm chứng	Nội dung	Kết quả
Đối chứng mức tệp mã hoá, chiều 1	Dữ liệu do bản hiện thực trong tiến trình tạo ra, giải mã bằng công cụ chuẩn age v1.2.1	Đạt
Đối chứng mức tệp mã hoá, chiều 2	Dữ liệu do công cụ chuẩn tạo ra, giải mã bằng bản hiện thực trong tiến trình	Đạt
Mở chéo kết, chiều 1	Kết tạo bằng bản dùng tiến trình con, mở bằng bản trong tiến trình	Đạt
Mở chéo kết, chiều 2	Kết tạo bằng bản trong tiến trình, mở bằng bản dùng tiến	Đạt

	trình con	
Giữ nguyên hàng rào xác thực	Sau khi thay bản hiện thực, mật khẩu sai vẫn bị từ chối đúng cách	Đạt

Nguồn: `crates/sv-age-rs/tests/interop.rs` và `src-tauri/tests/vault_interop.rs`. Công cụ đối chứng `age v1.2.1` tải từ nguồn chính thức, có lưu giá trị băm SHA-256 của tệp tải về để truy vết.

b.3. Định dạng tệp kết và sơ đồ phân cấp khoá do tác giả thiết kế

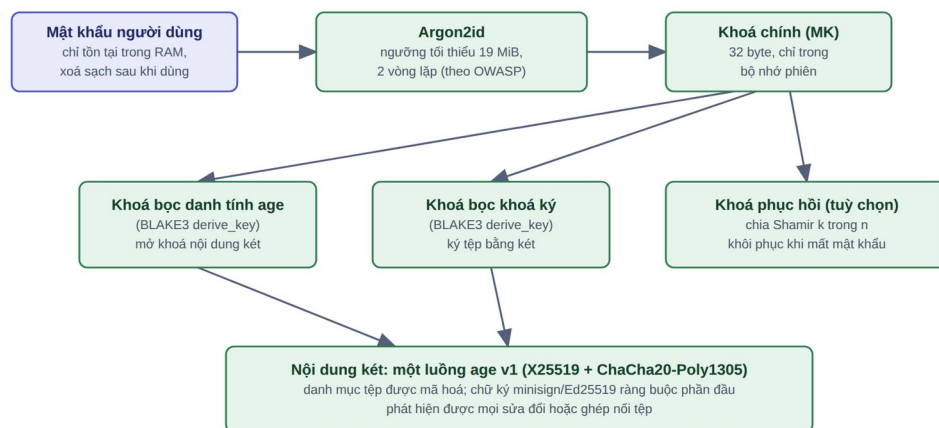
Đây là phần thiết kế cốt lõi của sản phẩm. Tác giả tự xác định cấu trúc tệp kết và cách sinh, bọc, lưu trữ các khoá; không sao chép định dạng của sản phẩm nào có sẵn.

Mật khẩu người dùng không được lưu ở bất kỳ đâu. Từ mật khẩu, hệ thống dẫn xuất khoá chính bằng thuật toán Argon2id với tham số tối thiểu 19 MiB bộ nhớ và 2 vòng lặp. Tác giả chọn ngưỡng này theo khuyến nghị OWASP nhằm làm chậm đáng kể tấn công dò mật khẩu bằng phần cứng chuyên dụng; hệ thống còn có cơ chế tự hiệu chỉnh tham số theo năng lực máy để không tụt xuống dưới ngưỡng.

Khoá chính chỉ tồn tại trong bộ nhớ phiên và sinh ra các khoá con theo từng mục đích riêng biệt bằng cơ chế dẫn xuất có tách miền. Việc tách miền là chủ ý: một khoá con bị lộ không kéo theo khoá con khác, và không khoá con nào suy ngược ra được khoá chính.

Hình 4. Phân cấp khoá và luồng mở kết an toàn

Mật khẩu không bao giờ được lưu; khoá chính chỉ tồn tại trong bộ nhớ phiên



Sai mật khẩu và tệp hỏng trả về hai mã lỗi khác nhau nhưng không tiết lộ thông tin phân biệt được (oracle-safe)

Hình 4. Sơ đồ phân cấp khoá và luồng mở kết do tác giả thiết kế

Nội dung kết được đóng gói thành một luồng dữ liệu mã hoá duy nhất, kèm danh mục tệp cũng ở dạng mã hoá — nhờ vậy người có tệp kết mà không có mật khẩu thì không biết bên trong có những gì, kể cả tên tệp. Toàn bộ phần đầu tệp được ràng buộc bằng một chữ ký số, nên mọi sửa đổi, kể cả thủ đoạn ghép nối phần đầu của tệp này với nội dung của tệp khác, đều bị phát hiện trước khi hệ thống chạm tới mật khẩu.

Bảng 4. Các nguyên hàm mật mã tác giả lựa chọn và lý do lựa chọn

Chức năng trong thiết kế	Nguyên hàm được chọn	Lý do lựa chọn
Dẫn xuất khoá từ mật khẩu	Argon2id	Chống dò mật khẩu bằng phần cứng; đặt ngưỡng 19 MiB / 2 vòng theo khuyến nghị OWASP
Băm nội dung và dẫn xuất khoá con	BLAKE3	Tốc độ cao trên thiết bị di động; hỗ trợ sẵn cơ chế dẫn xuất khoá có tách miền
Mã hoá nội dung kết	age v1 (X25519 + ChaCha20-Poly1305)	Định dạng mở, có đặc tả công khai nên bảo đảm liên thông; mã hoá kèm xác thực
Bọc các trường khoá trong phần đầu tệp	XSalsa20-Poly1305 (libsodium secretbox)	Thư viện đã được kiểm định lâu dài; phù hợp bọc dữ liệu ngắn
Chữ ký ràng buộc phần đầu tệp	Ed25519 (định dạng minisign)	Chữ ký ngắn, xác minh nhanh, định dạng phổ biến nên kiểm tra chéo được
Chia khoá phục hồi	Shamir k-trong-n (sss hazmat.c)	Bảo đảm về mặt toán học: dưới ngưỡng thì không lộ bất kỳ thông tin nào

Theo nguyên tắc nghề nghiệp, tác giả không tự thiết kế thuật toán mật mã mới mà lựa chọn và vận dụng các chuẩn công khai đã được cộng đồng khoa học kiểm chứng. Đóng góp của tác giả nằm ở kiến trúc, ở cách tổ chức và bảo vệ dữ liệu, và ở việc lựa chọn tham số có luận cứ.

b.4. Toàn bộ chức năng của ứng dụng

Ứng dụng cung cấp 38 lệnh nghiệp vụ. Tác giả nhóm chúng theo mục đích sử dụng thay vì theo thuật toán, để người dùng chọn công cụ theo việc cần làm chứ không cần biết bên dưới dùng kỹ thuật gì. Mục này trình bày đầy đủ từng nhóm; với mỗi chức năng nêu rõ đầu vào, cách xử lý và kết quả trả về.

Nhóm 1 — Két an toàn: nơi cất giữ nhiều tệp dưới một mật khẩu

Két an toàn là một tệp duy nhất (phần mở rộng .svault) đóng vai trò như một chiếc hộp có khoá: bên trong chứa nhiều tệp cùng danh mục của chúng, toàn bộ ở dạng mã hoá. Người dùng chỉ cần nhớ một mật khẩu thay vì quản lý nhiều tệp rời rạc. Danh mục tệp cũng được mã hoá, nên người có được tệp kết mà không có mật khẩu thì không biết bên trong có những gì — kể cả tên tệp.

Bảng 5. Nhóm 1

Chức năng	Đầu vào	Xử lý	Kết quả
Tạo kết mới	Nơi lưu, mật khẩu, tùy chọn chính sách khoá phục hồi k trong n	Sinh khoá chính từ mật khẩu bằng Argon2id; sinh cặp khoá nội dung và cặp khoá ký riêng cho kết; ghi tệp theo kiểu nguyên tử	Tệp .svault mới kèm thông tin tóm tắt của kết
Mở kết	Tệp kết, mật khẩu	Kiểm tra chữ ký ràng buộc trước, rồi mới dẫn xuất khoá và mở khoá nội dung — thứ tự này giúp phân biệt tệp hỏng với mật khẩu sai	Một mã phiên làm việc không mang thông tin bí mật
Khoá kết	Mã phiên	Xoá khoá chính khỏi bộ nhớ phiên	Phiên kết thúc; muốn mở lại phải nhập mật khẩu
Đổi mật khẩu kết	Mã phiên, mật khẩu mới	Dẫn xuất khoá chính mới và bọc lại các khoá nội bộ; nội dung không phải mã hoá lại	Kết dùng mật khẩu mới; các mảnh khoá phục hồi cũ vẫn dùng được
Xem thông tin kết	Mã phiên	Đọc phần đầu tệp đã được xác thực	Mã định danh kết, phiên bản định dạng, thời điểm tạo và sửa, số tệp bên trong, chính sách khoá

			phục hồi
Thêm tệp vào kết	Mã phiên, tệp nguồn, tên đặt trong kết	Nạp tệp, ghi vào danh mục đã mã hoá, ghi lại tệp kết theo kiểu nguyên tử	Tệp nằm trong kết; tệp nguồn bên ngoài không bị thay đổi
Liệt kê tệp trong kết	Mã phiên	Đọc danh mục đã giải mã trong bộ nhớ	Danh sách tên tệp, kích thước và thời điểm thêm
Trích xuất tệp khỏi kết	Mã phiên, tên tệp trong kết, nơi lưu	Giải mã và ghi ra tệp mới	Tệp khôi phục nguyên vẹn, giống hệt bản đã đưa vào
Ký tệp bằng kết	Mã phiên, tệp cần ký	Dùng khoá ký riêng của kết tạo chữ ký số	Tệp chữ ký, chứng minh tệp đến từ kết này và chưa bị sửa
Xuất khoá công khai của kết	Mã phiên	Đọc khoá công khai từ phần đầu tệp	Chuỗi khoá công khai để người khác kiểm tra chữ ký do kết tạo ra
Kiểm tra tệp kết còn nguyên vẹn	Tệp kết (không cần mật khẩu)	Kiểm tra chữ ký ràng buộc trên toàn bộ phần đầu tệp	Kết luận nguyên vẹn hay đã bị sửa — làm được mà không cần mở kết
Lấy vân tay tệp kết	Tệp kết	Tính giá trị băm BLAKE3 của toàn bộ tệp	Chuỗi vân tay để đối chiếu giữa hai máy

Nhóm 2 — Bảo vệ tệp đơn lẻ

Không phải lúc nào cũng cần đến kết. Khi chỉ muốn gửi một tệp đi hoặc cất riêng một tệp, người dùng có thể khoá trực tiếp tệp đó bằng mật khẩu. Tệp kết quả tự mang đủ thông tin để mở lại ở bất kỳ đâu, chỉ cần đúng mật khẩu.

Bảng 6. Nhóm 2

Chức năng	Đầu vào	Xử lý	Kết quả
Khoá một tệp bằng mật khẩu	Tệp bất kỳ, mật khẩu, nơi lưu kết quả	Dẫn xuất khoá từ mật khẩu bằng Argon2id rồi mã hoá có xác thực	Tệp đã khoá; sửa dù chỉ một byte cũng bị phát hiện khi mở
Mở khoá tệp	Tệp đã khoá, mật khẩu, nơi lưu kết quả	Dẫn xuất lại khoá và giải mã, đồng thời kiểm tra tính toàn vẹn	Tệp gốc khôi phục nguyên vẹn, hoặc thông báo lỗi nếu sai mật khẩu / tệp hỏng
Sao chép tệp an toàn	Tệp nguồn, nơi lưu	Sao chép và kiểm tra	Bản sao dùng cho

		kết quả	các bước xử lý tiếp theo mà không dừng đến tệp gốc
--	--	---------	--

Nhóm 3 — Chứng minh nguồn gốc và tính toàn vẹn

Mã hoá trả lời câu hỏi “ai đọc được”, còn nhóm chức năng này trả lời hai câu hỏi khác: “tệp này có đúng do người đó tạo ra không” và “tệp có bị sửa trên đường đi không”. Đây là nội dung thường bị bỏ qua trong các ứng dụng bảo mật phổ thông nhưng lại rất quan trọng khi trao đổi tài liệu.

Bảng 7. Nhóm 3

Chức năng	Đầu vào	Xử lý	Kết quả
Tạo cặp khoá ký	Thư mục lưu, tên định danh, mật khẩu bảo vệ khoá bí mật	Sinh cặp khoá Ed25519; khoá bí mật được bảo vệ bằng mật khẩu	Tệp khoá công khai để chia sẻ và tệp khoá bí mật để giữ riêng
Ký một tệp	Tệp cần ký, khoá bí mật, mật khẩu	Tạo chữ ký số theo định dạng minisign	Tệp chữ ký đi kèm tệp gốc
Kiểm tra chữ ký	Tệp, tệp chữ ký, khoá công khai của người ký	Xác minh chữ ký trên nội dung tệp	Kết luận đạt hoặc không đạt; sửa tệp sau khi ký sẽ làm chữ ký không còn hợp lệ
Lấy vân tay tệp	Tệp bất kỳ	Tính giá trị băm BLAKE3	Chuỗi vân tay dùng để đối chiếu hai bản sao của cùng một tệp
Đối chiếu tệp với vân tay cho trước	Tệp, chuỗi vân tay nhận được	Tính lại vân tay và so sánh, bỏ qua khác biệt về hoa thường và khoảng trắng	Kết luận tệp có đúng như bản gốc hay không
Xác minh tệp tải về	Tệp, vân tay và/hoặc chữ ký kèm khoá công khai	Kiểm tra đồng thời cả hai loại bằng chứng nếu có	Một kết luận đạt/không đạt duy nhất, tránh phải dùng nhiều công cụ rời

Nhóm 4 — Sao lưu và khôi phục bằng chia sẻ bí mật ngưỡng

Nguyên tắc không lưu khoá đem lại an toàn nhưng cũng tạo rủi ro: quên mật khẩu là mất dữ liệu. Nhóm chức năng này giải quyết bằng sơ đồ chia sẻ bí mật Shamir: bí mật được chia thành n mảnh, cần đúng k mảnh bất kỳ để khôi phục. Một mảnh đơn lẻ không tiết lộ bất cứ điều gì — đây là tính chất toán học của sơ đồ, không phải quy ước.

Nhờ vậy có thể gửi các mảnh cho nhiều người hoặc cất ở nhiều nơi mà không ai một mình mở được.

Bảng 8. Nhóm 4

Chức năng	Đầu vào	Xử lý	Kết quả
Chia một bí mật thành nhiều mảnh	Chuỗi bí mật (mật khẩu, khoá, cụm từ khôi phục), tổng số mảnh n , ngưỡng k	Sinh khoá ngẫu nhiên, chia khoá theo Shamir, niêm phong bí mật bằng khoá đó	n tệp mảnh cùng một tệp dữ liệu niêm phong; cần k mảnh và tệp này để khôi phục
Chia một tệp thành nhiều mảnh	Tệp bất kỳ, tổng số mảnh, ngưỡng	Tương tự nhưng đối tượng là toàn bộ nội dung tệp	Các tệp mảnh nhỏ gọn cùng một tệp dữ liệu niêm phong
Khôi phục từ các mảnh	Đủ số mảnh theo ngưỡng (dạng tệp hoặc chuỗi dán vào), tệp dữ liệu niêm phong	Ghép khoá từ các mảnh rồi mở niêm phong	Bí mật hoặc tệp ban đầu; thiếu mảnh thì báo rõ còn thiếu bao nhiêu
Tạo mảnh khôi phục cho kết	Mã phiên của kết đang mở, tổng số mảnh, ngưỡng	Chia khoá dự phòng của kết theo Shamir	Các mảnh dùng để mở lại kết khi quên mật khẩu
Khôi phục kết từ các mảnh	Tệp kết, đủ số mảnh theo ngưỡng	Ghép khoá dự phòng và mở kết	Phiên làm việc mở, không cần mật khẩu gốc
Xuất mảnh ra mã QR	Các chuỗi mảnh	Sinh ảnh mã QR cho từng mảnh	Các ảnh QR để in ra hoặc chuyển sang máy khác bằng camera
Khôi phục từ ảnh mã QR	Đủ số ảnh QR theo ngưỡng, tệp dữ liệu niêm phong	Đọc mã QR từ ảnh rồi khôi phục như trên	Bí mật hoặc tệp ban đầu

Nhóm 5 — Che giấu dữ liệu trong ảnh và phát hiện dữ liệu ẩn

Che giấu không thay thế mã hoá mà bổ sung cho nó: dữ liệu được mã hoá trước rồi mới giấu vào ảnh, nên ngay cả khi bị phát hiện thì vẫn không đọc được nếu không có mật khẩu. Chức năng phát hiện đi kèm giúp người dùng hiểu rõ giới hạn của việc che giấu — một nội dung có giá trị trong huấn luyện.

Bảng 9. Nhóm 5

Chức năng	Đầu vào	Xử lý	Kết quả
Giấu dữ liệu vào ảnh	Ảnh nền, tệp cần giấu, mật khẩu, tùy	Mã hoá tệp trước, sau đó nhúng vào	Ảnh mới nhìn bằng mắt không khác ảnh

	chọn phân tán dữ liệu	các bit ít quan trọng của ảnh	gốc, mang dữ liệu đã mã hoá bên trong
Lấy dữ liệu đã giấu ra	Ảnh có dữ liệu ẩn, mật khẩu, thư mục lưu	Trích các bit ẩn rồi giải mã	Tập ban đầu, giữ nguyên tên và phần mở rộng
Phát hiện dấu hiệu dữ liệu ẩn	Ảnh bất kỳ	Phân tích dữ liệu thừa sau điểm kết thúc ảnh và thống kê bit ít quan trọng	Mức độ nghi ngờ kèm giải thích; kết quả thấp nghĩa là “các phép thử này không phát hiện được”, không phải bảo đảm ảnh sạch

Nhóm 6 — Thuỷ vân chống giả mạo ảnh

Thuỷ vân dễ vỡ là dấu vô hình gắn với mật khẩu, được nhúng vào ảnh sao cho mọi chỉnh sửa đều phá vỡ nó. Khác với chữ ký số vốn chỉ cho biết tệp có bị sửa hay không, thuỷ vân còn chỉ ra được vùng nào của ảnh bị can thiệp.

Bảng 10. Nhóm 6

Chức năng	Đầu vào	Xử lý	Kết quả
Nhúng thuỷ vân	Ảnh PNG hoặc BMP, mật khẩu, nơi lưu	Tính mã xác thực theo từng khối ảnh, khoá bằng mật khẩu, nhúng vào bit ít quan trọng	Ảnh đã đóng dấu, nhìn không khác ảnh gốc; tệp gốc không bị sửa
Kiểm tra thuỷ vân	Ảnh đã đóng dấu, mật khẩu	Tính lại mã xác thực từng khối và đối chiếu	Kết luận ảnh còn nguyên hay đã bị sửa, kèm vị trí các vùng bị thay đổi

Nhóm 7 — Siêu dữ liệu ẩn trong tệp

Ảnh chụp bằng điện thoại thường mang theo toạ độ GPS nơi chụp, kiểu máy, thời điểm và đôi khi cả tên chủ sở hữu. Người dùng hiếm khi biết điều này, và đây là một trong những kênh lộ thông tin phổ biến nhất khi chia sẻ ảnh. Nhóm chức năng này cho phép xem, xoá và đối chiếu siêu dữ liệu ngay trên máy.

Bảng 11. Nhóm 7

Chức năng	Đầu vào	Xử lý	Kết quả
Xem siêu dữ liệu của tệp	Tập ảnh	Đọc và nhóm các thẻ theo loại; nhóm toạ	Danh sách thẻ theo nhóm kèm định dạng

		độ GPS được tách riêng vì nhạy cảm nhất	và kiểu MIME; thao tác chỉ đọc, không sửa tệp
Xoá siêu dữ liệu	Tệp ảnh, nơi lưu bản sạch	Dựng lại tệp từ dữ liệu ảnh, loại bỏ khối EXIF, hồ sơ màu, chú thích và các khối văn bản; ghi theo kiểu nguyên tử	Bản sao đã sạch siêu dữ liệu; tệp gốc giữ nguyên; báo cáo số thẻ trước và sau
So sánh siêu dữ liệu hai tệp	Hai tệp ảnh	Đối chiếu tập thẻ của hai tệp, bỏ qua tên tệp và dấu thời gian của hệ thống	Danh sách thẻ chỉ có ở tệp thứ nhất, chỉ có ở tệp thứ hai, và các thẻ khác giá trị
Kiểm tra mô-đun sẵn sàng	Không có	Báo trạng thái sẵn sàng của mô-đun cho giao diện	Giao diện biết để bật hoặc tắt nhóm chức năng tương ứng

Nhóm 8 — Thông tin ứng dụng

Một lệnh duy nhất phục vụ minh bạch phiên bản: cho biết ứng dụng đang chạy phiên bản nào, hỗ trợ định dạng kết đến phiên bản nào và dùng bộ thuật toán phiên bản máy. Thông tin này cần cho việc đối chiếu khi trao đổi tệp giữa các máy.

Bảng 12. Nhóm 8

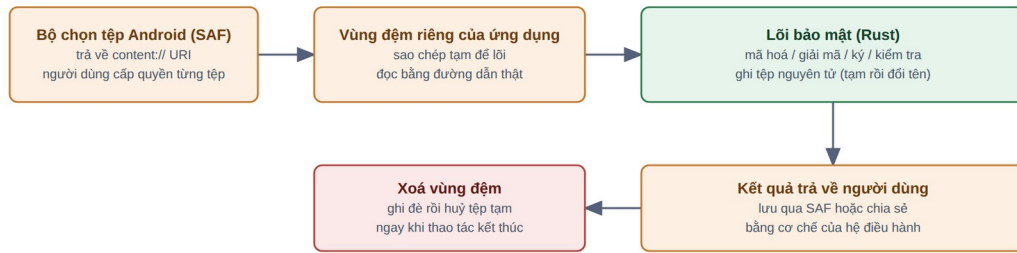
Chức năng	Đầu vào	Xử lý	Kết quả
Xem thông tin phiên bản	Không có	Đọc các hằng số phiên bản được biên dịch vào ứng dụng	Phiên bản ứng dụng, phiên bản giao ước lệnh, phiên bản định dạng kết, phiên bản bộ thuật toán

b.5. Luồng xử lý tệp trên Android

Android không cho ứng dụng truy cập tự do vào bộ nhớ thiết bị. Người dùng chọn tệp qua bộ chọn của hệ điều hành và cấp quyền cho từng tệp. Tác giả thiết kế luồng xử lý đưa dữ liệu vào vùng lưu trữ riêng của ứng dụng, xử lý, trả kết quả rồi xoá vùng đệm — cách làm này giữ nguyên được toàn bộ nghiệp vụ lỗi vốn làm việc trên đường dẫn tệp thật, thay vì phải sửa lại toàn bộ giao ước dữ liệu của hệ thống.

Hình 5. Luồng xử lý tệp trên Android và ranh giới tin cậy

Mọi xử lý diễn ra trên thiết bị; không có kết nối mạng trong toàn bộ luồng



Ranh giới tin cậy: toàn bộ khối trên nằm trong vùng lưu trữ riêng của ứng dụng, được hệ điều hành cách ly và mã hoá ở mức tệp (File-Based Encryption).

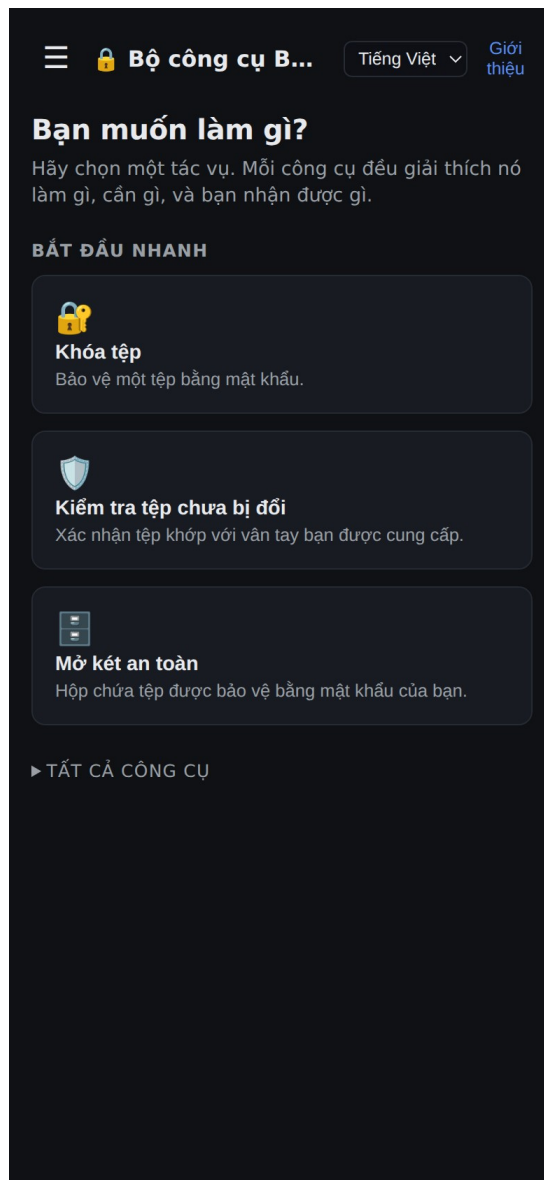
Ứng dụng KHÔNG khai báo quyền truy cập mạng (INTERNET).

Điểm cần ghi nhận trung thực: bản sao tạm ở dạng rõ tồn tại trong vùng đệm trong thời gian thao tác — đã được ghi nhận trong mô hình mối đe dọa.

Hình 5. Luồng xử lý tệp trên Android và ranh giới tin cậy

b.6. Giao diện người dùng

Giao diện do tác giả thiết kế theo hướng giảm tải nhận thức: mỗi màn hình chỉ hiển thị các bước cần thiết để hoàn thành công việc, phần giải thích kỹ thuật đặt trong mục “Thông tin thêm” có thể mở rộng. Riêng cảnh báo có nguy cơ gây mất dữ liệu vĩnh viễn thì luôn hiển thị thường trực, không thu gọn. Toàn bộ giao diện có tiếng Việt và tiếng Anh; vùng chạm được thiết kế tối thiểu 44 điểm ảnh theo khuyến nghị về khả năng tiếp cận.



Hình 6. Màn hình chính với các nhóm công cụ theo mục đích

Bộ công cụ B...

Tiếng Việt

Giới thiệu

Khóa tệp bằng mật khẩu

Biến bất kỳ tệp nào thành tệp đã khóa mà chỉ mật khẩu của bạn mới mở được.

► Thông tin thêm

1 Chọn tệp cần khóa

Kéo thả tệp vào đây, hoặc bấm Duyệt...

Duyệt...

2 Đặt mật khẩu

mật khẩu

Xác nhận mật khẩu

nhập lại mật khẩu

Gõ sai ở đây là không thể khôi phục — tệp sẽ không bao giờ mở được.

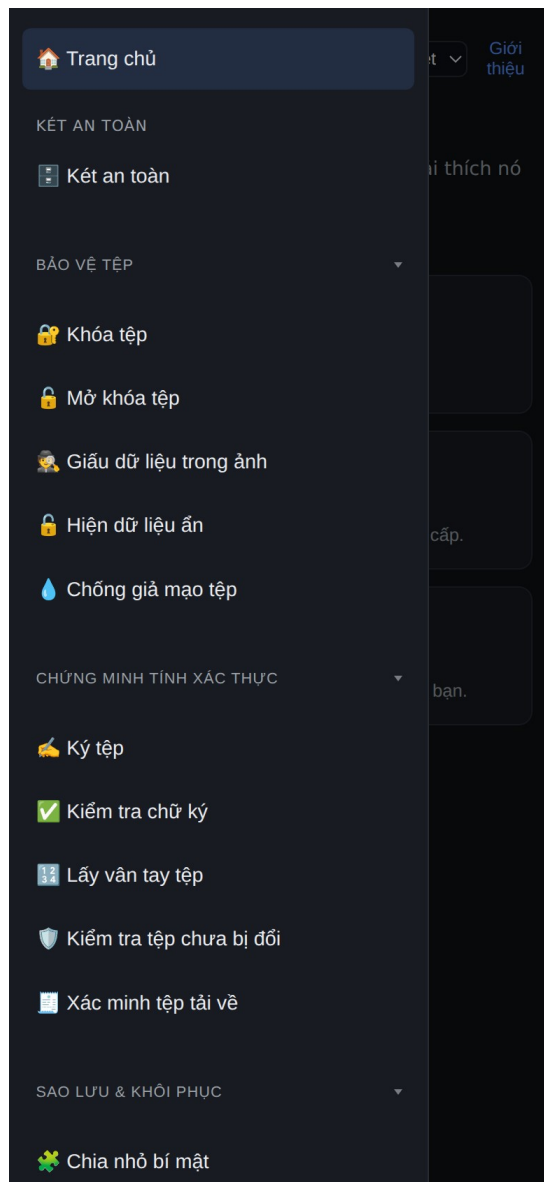
3 Nơi lưu tệp đã khóa

/đường-dẫn/tôi/tệp.svenc

Lưu thành...

Khóa tệp

Hình 7. Màn hình khoá tệp — thao tác theo ba bước rõ ràng



Hình 8. Ngăn kéo điều hướng nhóm công cụ theo nghiệp vụ

Hình 9. Màn hình chia bí mật theo ngưỡng k trong n

Ghi chú về ảnh chụp giao diện: các hình trên được kết xuất từ chính mã giao diện của sản phẩm ở kích thước màn hình điện thoại, với cầu nối tới lõi được mô phỏng trả về đúng giá trị mà gốc hợp thành Android tạo ra, nhờ vậy logic giao diện thật được thực thi.

c) Kết quả của giải pháp

c.1. Sản phẩm đã tạo ra

- Ứng dụng Android đóng gói dạng APK (47.4 MB), chứa lỗi bảo vệ dữ liệu biên dịch cho kiến trúc ARM64, đã kiểm tra tĩnh nội dung gói.
- Mã nguồn đầy đủ gồm 15 thành phần độc lập và giao diện web tĩnh, kèm 272 hàm kiểm thử tự động.
- Bộ tài liệu kiến trúc, mô hình mối đe dọa và hướng dẫn triển khai.
- Quy trình kiểm thử tự động chạy trên máy chủ tích hợp liên tục.

c.2. Các chỉ tiêu kỹ thuật đạt được

Bảng 13. Các chỉ tiêu kỹ thuật đo được tại thời điểm lập hồ sơ

Chỉ tiêu	Giá trị đạt được	Cách xác định
Số chức năng nghiệp vụ	38 lệnh	Đếm trực tiếp từ mã nguồn
Số hàm kiểm thử tự động	272 hàm	Đếm trực tiếp từ mã nguồn
Kiểm thử trên máy chủ	263 đạt / 0 lỗi	Nhật ký chạy bộ kiểm thử
Kiểm thử lỗi trên kiến trúc ARM64 (10 bộ)	146 đạt / 0 lỗi	Chạy dưới trình giả lập kiến trúc
Kiểm chứng tương thích định dạng	5 phép đối chứng đạt	Đối chứng với công cụ chuẩn age v1.2.1
Kiến trúc thư viện trong gói cài đặt	64-bit ARM aarch64	Đọc phần đầu ELF của tệp trong gói
Quyền ứng dụng yêu cầu	Không khai báo quyền nào	Đọc tệp kê khai trong gói cài đặt
Giao diện nhúng sẵn trong ứng dụng	Có	Bảng tài nguyên trong thư viện native

Toàn bộ số liệu được sinh tự động từ mã nguồn và nhật ký kiểm thử, không nhập tay, nhằm bảo đảm tính chính xác và khả năng kiểm tra lại.

c.3. Mức độ kiểm chứng

Tác giả xác định rõ từng mức kiểm chứng đã đạt được, để mỗi tuyên bố kỹ thuật trong hồ sơ đều gắn với một bằng chứng cụ thể.

Hình 6. Các mức kiểm chứng đã đạt được và phần còn lại

Phân biệt rõ điều đã chứng minh bằng máy và điều còn phải kiểm tra trên thiết bị thật



Nguyên tắc của hồ sơ: mỗi tuyên bố kỹ thuật đều gắn với một mức kiểm chứng cụ thể ở trên.

Hình 10. Các mức kiểm chứng của sản phẩm

Về mức thực thi trên ARM64: việc kiểm chứng được tiến hành bằng trình giả lập kiến trúc, chạy 10 bộ kiểm thử của các thành phần mật mã và giao tiếp thư viện hệ thống với kết quả 146 đạt, 0 lỗi. Đây là kiểm chứng mã máy ARM64 của lỗi — cùng loại mã lệnh sẽ chạy trên điện thoại thật.

4. Tự đánh giá giải pháp

a) Tính mới và tính sáng tạo

Điểm mới

Tính mới của sáng kiến không nằm ở việc “có thêm một ứng dụng mã hoá”, mà ở cách giải quyết những vấn đề kỹ thuật mà các giải pháp hiện có chưa xử lý được trên nền tảng di động. Dưới đây là năm điểm mới, mỗi điểm kèm bằng chứng kiểm tra lại được trong mã nguồn.

Điểm mới 1 — Vượt rào cản cấm sinh tiến trình mà không phá vỡ định dạng dữ liệu. Các công cụ mật mã tin cậy hiện nay phần lớn ở dạng tệp nhị phân chạy độc lập nên không chuyển thẳng sang di động được. Tác giả đặt điểm nổi trù tượng tại vị trí bộ mã hoá nội dung, cho phép thay bằng bản hiện thực chạy trong tiến trình mà tệp tạo ra vẫn đọc được bằng công cụ chuẩn. Cách làm này giữ được tính liên thông với hệ sinh thái mở và tránh khoá người dùng vào một sản phẩm.

Bằng chứng: 5 phép kiểm chứng đối chứng hai chiều với công cụ chuẩn age v1.2.1, cả ở mức tệp mã hoá lẫn mức mở chéo tệp kết hoàn chỉnh.

Điểm mới 2 — Một lõi bảo vệ dữ liệu duy nhất, tự chọn cấu hình theo nền tảng khi biên dịch. Thay vì viết hai ứng dụng song song rồi phải đồng bộ thủ công, tác giả tổ chức toàn bộ nghiệp vụ vào một lõi duy nhất; phần khác biệt giữa các nền tảng được cô lập trong một tệp cấu hình hợp thành và được trình biên dịch tự động lựa chọn. Nhờ vậy không tồn tại nguy cơ hai nền tảng dùng hai phiên bản thuật toán khác nhau.

Bằng chứng: Kiểm tra trực tiếp kết quả biên dịch cho thấy hai nền tảng chọn đúng hai gốc hợp thành khác nhau từ cùng một mã nguồn.

Điểm mới 3 — Viết lại mô-đun xử lý siêu dữ liệu để chức năng có mặt thật trên di động. Công cụ xử lý siêu dữ liệu phổ biến hiện nay viết bằng ngôn ngữ Perl nên không thể chạy trên Android dưới bất kỳ hình thức nào. Thay vì bỏ chức năng, tác giả hiện thực lại ba nghiệp vụ xem, xoá và so sánh siêu dữ liệu bằng Rust chạy trong tiến trình ứng dụng. Người dùng kiểm tra và xoá được toạ độ định vị, thông tin thiết bị và tên tác giả trong ảnh ngay trên điện thoại — đúng nơi những dữ liệu đó phát sinh.

Bằng chứng: Năm kiểm thử tự động trên ảnh có siêu dữ liệu: đọc đúng thẻ, xoá sạch về 0 thẻ, giữ nguyên tệp gốc, từ chối ghi đè tệp đích, từ chối định dạng ngoài phạm vi.

Điểm mới 4 — Quy tắc phân loại lỗi không tạo kênh phân biệt cho kẻ tấn công. Hệ thống phân biệt rõ ở tầng mã giữa “sai mật khẩu” và “tệp bị hỏng hoặc bị sửa”, nhưng tác giả thiết kế quy tắc quy lỗi sao cho sự khác biệt đó không trở thành công cụ dò tìm: thất bại khi giải mã nội dung được quy về lỗi tệp hỏng, vì tại thời điểm đó chữ ký ràng buộc và khoá đã được xác thực xong.

***Bằng chứng:** Có kiểm thử riêng khẳng định cả hai bản hiện thực dùng chung một quy tắc quy lỗi, để hai nền tảng không thể lệch nhau về hành vi này.*

Điểm mới 5 — Ngoại tuyến bằng ràng buộc kỹ thuật thay vì bằng cam kết. Ứng dụng không khai báo quyền truy cập mạng trong tệp kê khai. Người dùng không phải tin vào lời hứa “chúng tôi không gửi dữ liệu đi”, mà tự kiểm tra được bằng công cụ phân tích gói cài đặt tiêu chuẩn.

***Bằng chứng:** Kiểm tra tệp kê khai của gói cài đặt: danh sách quyền rỗng hoàn toàn.*

Điểm sáng tạo

Ngoài các điểm mới về kỹ thuật, sáng kiến còn có những điểm sáng tạo trong cách tiếp cận và cách tổ chức sản phẩm.

Điểm sáng tạo 1 — Một sản phẩm phục vụ đồng thời hai mục đích khác nhau. Thông thường công cụ nghiệp vụ và học cụ giảng dạy là hai sản phẩm riêng. Tác giả thiết kế sản phẩm sao cho mỗi nhóm chức năng vừa giải quyết một nhu cầu công tác có thật, vừa minh hoạ trực quan một nguyên lý trong chương trình an toàn thông tin. Việc học viên dùng chính công cụ mình đang học để bảo vệ dữ liệu của mình tạo ra động lực học tập mà bài giảng lý thuyết khó có được.

Điểm sáng tạo 2 — Chuyển giới hạn của công cụ thành nội dung huấn luyện. Chức năng phát hiện dữ liệu ẩn được thiết kế để báo kết quả kèm lời giải thích rằng “mức thấp nghĩa là các phép thử này không phát hiện được”, chứ không phải “ảnh sạch”. Cách trình bày này biến một giới hạn kỹ thuật thành bài học về ranh giới của công cụ phân tích — điều mà phần mềm thương mại thường che giấu để sản phẩm trông mạnh hơn.

Điểm sáng tạo 3 — Thiết kế để tự chứng minh thay vì để được tin tưởng. Tác giả chủ trương mọi tuyên bố quan trọng đều phải kiểm tra lại được bằng công cụ độc lập: tính ngoại tuyến kiểm tra bằng danh sách quyền trong gói cài đặt, tính tương thích kiểm tra bằng đối chứng với công cụ chuẩn, tính đúng đắn kiểm tra bằng bộ kiểm thử

kèm theo. Đây là cách tiếp cận khác với phần mềm bảo mật thông thường vốn yêu cầu người dùng tin vào uy tín nhà cung cấp.

Điểm sáng tạo 4 — Sinh hồ sơ kỹ thuật tự động từ mã nguồn. Toàn bộ số liệu trong hồ sơ này được sinh tự động từ mã nguồn và nhật ký kiểm thử qua một tệp dữ kiện trung gian. Khi mã nguồn thay đổi, chỉ cần chạy lại là mọi con số tự cập nhật. Cách làm này loại bỏ hoàn toàn nguy cơ số liệu trong tài liệu lệch với sản phẩm thực tế — một vấn đề phổ biến của tài liệu kỹ thuật.

Điểm sáng tạo 5 — Suy giảm chức năng an toàn được đưa vào thiết kế ngay từ đầu. Khi một định dạng nằm ngoài phạm vi xử lý, hệ thống từ chối bằng lỗi có mã thay vì báo thành công giả. Nguyên tắc “thà từ chối còn hơn báo sai” được áp dụng nhất quán, vì trong bảo vệ dữ liệu, một báo cáo “đã xoá siêu dữ liệu” sai sự thật nguy hiểm hơn nhiều so với việc thông báo không xử lý được.

Về quyền tác giả đối với sản phẩm

Toàn bộ ý tưởng giải pháp, kiến trúc hệ thống, định dạng tệp kết, sơ đồ phân cấp khoá, quy tắc phân loại lỗi, mô-đun xử lý siêu dữ liệu, giao diện và mã nguồn là do tác giả tự thiết kế và trực tiếp xây dựng.

Các nguyên hàm mật mã cơ sở là những chuẩn công khai đã được cộng đồng khoa học kiểm chứng, do tác giả lựa chọn và vận dụng có luận cứ. Đây là nguyên tắc nghề nghiệp bắt buộc trong lĩnh vực mật mã: tự chế thuật toán mật mã mới là điều phải tránh.

b) Khả năng áp dụng

Sáng kiến áp dụng được ngay với điều kiện triển khai tối thiểu: chỉ cần một điện thoại Android, không cần máy chủ, không cần kết nối mạng, không phát sinh chi phí bản quyền và không yêu cầu quyền quản trị thiết bị.

Bảng 14. Đối tượng và phạm vi áp dụng

Đối tượng	Cách sử dụng	Điều kiện cần
Giảng viên an toàn thông tin	Bảo vệ giáo án, đề bài và đáp án thực hành, kết quả nghiên cứu chưa công bố; dùng làm học cụ minh hoạ trực tiếp trên lớp	Điện thoại Android; không cần hạ tầng bổ sung
Học viên	Thực hành các bài về mã hoá, chữ ký số, chia sẻ bí mật ngưỡng, kiểm tra toàn vẹn, giấu tin, phát hiện giấu	Điện thoại Android của cá nhân

	tin và xử lý siêu dữ liệu	
Cán bộ, nhân viên trong đơn vị	Bảo vệ tài liệu nghiệp vụ nội bộ khi mang theo trên thiết bị di động; kiểm tra tính toàn vẹn và nguồn gốc của tệp nhận được	Điện thoại Android; hướng dẫn sử dụng cơ bản khoảng 30 phút

b.1. Giá trị đối với công tác giảng dạy an toàn thông tin

Điểm mạnh của sản phẩm trong đào tạo là mỗi chức năng đều tương ứng với một nguyên lý trong chương trình, và học viên quan sát được trực tiếp hệ quả của nguyên lý đó trên thiết bị của mình thay vì chỉ nghe giảng lý thuyết.

Bảng 15. Ánh xạ chức năng của sản phẩm với nội dung giảng dạy

Chức năng	Nội dung giảng dạy minh hoạ	Gợi ý bài thực hành
Tạo và mở kết an toàn	Dẫn xuất khoá từ mật khẩu; vì sao mật khẩu yếu vẫn nguy hiểm dù thuật toán mạnh	So sánh thời gian mở kết khi thay đổi tham số dẫn xuất khoá
Khoá / mở khoá tệp	Mã hoá có xác thực; phân biệt bảo mật và toàn vẹn	Sửa một byte của tệp đã mã hoá rồi quan sát ứng dụng từ chối giải mã
Ký tệp và kiểm tra chữ ký	Mật mã khoá công khai; chứng minh nguồn gốc	Ký tệp, đổi một ký tự trong tệp, kiểm tra lại chữ ký
Vân tay tệp và kiểm tra toàn vẹn	Hàm băm mật mã; ứng dụng trong kiểm tra tệp tải về	Đối chiếu vân tay của cùng một tệp trên hai thiết bị
Chia bí mật k trong n	Chia sẻ bí mật ngưỡng; nguyên tắc tách quyền kiểm soát	Chia khoá cho ba học viên, chứng minh hai người mới khôi phục được
Giấu tin và phát hiện giấu tin	Giấu tin trong ảnh; giới hạn của che giấu so với mã hoá	Giấu tệp vào ảnh rồi dùng chính công cụ phát hiện để tìm dấu hiệu
Thuỷ vân dễ vỡ	Phát hiện sửa đổi cục bộ trên ảnh	Chỉnh sửa một vùng ảnh đã đóng dấu và xác định vùng bị sửa
Xem và xoá siêu dữ liệu	Kênh lộ thông tin ngoài nội dung; quyền riêng tư trong ảnh số	Xem toạ độ định vị trong ảnh tự chụp, xoá rồi kiểm tra lại
Quy tắc phân loại lỗi	Tấn công dựa trên thông báo lỗi và cách phòng tránh	Đọc mã nguồn phần quy lỗi, phân tích vì sao gộp hai trường hợp

Ngoài giá trị minh hoạ, mã nguồn mở còn cho phép tổ chức bài học ở mức cao hơn: đọc và phân tích cách hiện thực một nguyên lý, nhận xét về mô hình mỗi đe dọa, hoặc rà soát mã nguồn để tìm điểm cần cải thiện. Đây là hình thức huấn luyện sát thực tế mà tài liệu lý thuyết đơn thuần khó thay thế được.

c) Hiệu quả

Hiệu quả kinh tế

Sáng kiến không phát sinh chi phí bản quyền phần mềm, không yêu cầu đầu tư máy chủ, không có chi phí thuê bao dịch vụ và chạy trên thiết bị sẵn có của người dùng. Hiệu quả kinh tế thể hiện ở việc tránh được chi phí mua sắm giải pháp thương mại tương đương, chi phí duy trì hạ tầng đi kèm, và chi phí chuyển đổi khi thay nhà cung cấp — vì sản phẩm do đơn vị hoàn toàn làm chủ về mã nguồn.

Tác giả không quy đổi thành con số tiền cụ thể, vì con số đó phụ thuộc quy mô triển khai và chính sách mua sắm của từng đơn vị; đưa ra ước lượng khi chưa triển khai sẽ không có căn cứ.

Hiệu quả kỹ thuật

So sánh với các giải pháp đã biết ở mục 1.2, sáng kiến mang lại những cải thiện kỹ thuật sau đây.

- Bảo vệ dữ liệu ở trạng thái lưu trữ ngay trên thiết bị, lấp đúng khoảng trống mà mã hoá toàn thiết bị của hệ điều hành không xử lý được: khi máy đã mở khoá, dữ liệu trong két vẫn đòi hỏi mật khẩu riêng.
- Dữ liệu tiếp tục được bảo vệ sau khi rời khỏi thiết bị, khác với mã hoá toàn thiết bị vốn mất tác dụng ngay khi tệp được sao chép ra ngoài.
- Phát hiện được mọi sửa đổi trên tệp nhờ chữ ký ràng buộc, kể cả thủ đoạn ghép nối phần đầu tệp này với nội dung tệp khác.
- Khắc phục rủi ro mất dữ liệu do quên mật khẩu bằng cơ chế chia khoá theo ngưỡng, không phải gửi khoá cho bên thứ ba giữ hộ như các dịch vụ khôi phục tài khoản thông thường.
- Xử lý được siêu dữ liệu ẩn ngay trên điện thoại, khác với các ứng dụng kết thương mại hiểm khi có chức năng này.
- Tệp tạo ra theo chuẩn mở nên liên thông với hệ sinh thái công cụ sẵn có, khác với các ứng dụng dùng định dạng riêng khoá người dùng vào sản phẩm.

Bảng dưới đây trình bày rõ phạm vi bảo vệ và giới hạn. Việc công bố giới hạn là một phần của thiết kế: người dùng chỉ sử dụng đúng công cụ khi biết công cụ không bảo vệ được điều gì.

Bảng 16. Mô hình mối đe dọa: phạm vi bảo vệ và giới hạn

Tình huống	Có bảo vệ?	Giải thích
Mất hoặc thất lạc điện thoại khi máy đang khoá	Có	Dữ liệu trong kết ở dạng mã hoá; không có mật khẩu thì không mở được
Người khác mượn máy khi máy đã mở khoá	Có, một phần	Kết vẫn cần mật khẩu riêng; nhưng nếu phiên đang mở thì nội dung có thể xem được
Sao chép tệp kết ra khỏi thiết bị	Có	Tệp kết tự bảo vệ, mở ở nơi khác vẫn cần mật khẩu
Tệp bị sửa đổi hoặc hỏng trên đường truyền	Có	Chữ ký ràng buộc phát hiện mọi thay đổi, kể cả ghép nối tệp
Ảnh chia sẻ mang theo tọa độ định vị	Có	Chức năng xoá siêu dữ liệu loại bỏ trước khi chia sẻ
Lộ tệp do gửi nhầm qua ứng dụng khác	Có, một phần	Nếu gửi tệp kết thì bên nhận vẫn cần mật khẩu; nếu gửi tệp đã trích xuất thì không
Thiết bị đã bị chiếm quyền điều khiển ở mức hệ điều hành	Không	Phần mềm độc hại có quyền cao đọc được bộ nhớ tiến trình khi kết đang mở
Người dùng quên mật khẩu và không tạo mảnh phục hồi	Không	Hệ quả tất yếu của nguyên tắc không lưu kho; đã có cơ chế phòng ngừa là chia mảnh
Kẻ tấn công cưỡng ép người dùng cung cấp mật khẩu	Không	Nằm ngoài phạm vi của biện pháp kỹ thuật

Hiệu quả về quốc phòng – an ninh và xã hội

- Góp phần bảo đảm an toàn cho dữ liệu nội bộ phát sinh trong công tác và huấn luyện khi được lưu trữ, sử dụng trên thiết bị di động có tính cơ động cao.
- Bảo đảm chủ quyền dữ liệu: toàn bộ quá trình xử lý diễn ra trên thiết bị, khoá do người dùng nắm giữ, sản phẩm không có thành phần máy chủ và không khai báo quyền truy cập mạng nên về mặt kỹ thuật không thể gửi dữ liệu ra ngoài.
- Giảm phụ thuộc vào phần mềm bảo mật nước ngoài mã nguồn đóng: toàn bộ thiết kế và mã nguồn do tác giả xây dựng, đơn vị kiểm soát và kiểm chứng lại được.

- Hạn chế thói quen chuyển tài liệu nội bộ qua ứng dụng nhắn tin hoặc lưu trữ đám mây không kiểm soát, bằng cách cung cấp phương án thay thế thuận tiện ngay trên máy.
- Nâng cao nhận thức và kỹ năng an toàn thông tin cho cán bộ, học viên thông qua việc trực tiếp sử dụng và quan sát kết quả của các biện pháp bảo vệ dữ liệu.
- Góp phần đào tạo nguồn nhân lực làm chủ công nghệ bảo mật: học viên không chỉ dùng công cụ mà còn đọc được mã nguồn, hiểu được nguyên lý và có thể phát triển tiếp.

Tác giả xác định rõ phạm vi: sản phẩm là công cụ hỗ trợ kỹ thuật do tác giả tự xây dựng phục vụ công tác và huấn luyện. Việc sử dụng cho bất kỳ loại tài liệu nào phải tuân thủ quy định hiện hành của cơ quan có thẩm quyền về bảo vệ bí mật nhà nước và quy chế của đơn vị. Hồ sơ này không đưa ra tuyên bố về việc sản phẩm được phép xử lý tài liệu thuộc danh mục bí mật nhà nước ở cấp độ cụ thể.

d) Mức độ triển khai, phát triển trong thời gian tới

Mức độ hoàn thành hiện tại

Bảng 17. Mức độ hoàn thành theo hạng mục

Hạng mục	Mức độ	Cách xác định
Thiết kế kiến trúc và định dạng dữ liệu	Hoàn thành	Tài liệu kiến trúc và mã nguồn
Lỗi bảo vệ dữ liệu và các nghiệp vụ	Hoàn thành	Bộ kiểm thử tự động chạy đạt trên máy chủ
Mô-đun xử lý siêu dữ liệu bằng Rust	Hoàn thành	Năm kiểm thử tự động trên ảnh có siêu dữ liệu
Tương thích định dạng giữa hai bản hiện thực	Hoàn thành	Đối chứng hai chiều với công cụ chuẩn
Biên dịch cho kiến trúc Android	Hoàn thành	Kiểm tra tệp đối tượng là mã ARM64
Thực thi lỗi trên kiến trúc ARM64	Hoàn thành	Chạy bộ kiểm thử dưới trình giả lập kiến trúc
Giao diện cho màn hình điện thoại	Hoàn thành	Kết xuất và kiểm tra bố cục ở kích thước điện thoại
Đóng gói tệp cài đặt Android	Hoàn thành	Kiểm tra tính nội dung gói cài đặt
Kiểm thử nghiệm thu trên thiết bị thật	Tác giả thực hiện theo Phụ lục A	Quy trình 15 bước có tiêu chí đạt cho từng bước
Tích hợp kho khoá phần cứng của Android	Định hướng phát triển	Chưa hiện thực trong phiên bản này

Hướng phát triển

- **Hướng 1 – Hoàn tất kiểm thử nghiệm thu trên nhiều dòng máy:** Chạy toàn bộ kịch bản nghiệp vụ tại Phụ lục A trên nhiều dòng điện thoại và nhiều phiên bản Android, ghi nhận kết quả làm cơ sở đánh giá hiệu quả thực tế.
- **Hướng 2 – Tích hợp kho khoá phần cứng và xác thực sinh trắc:** Sử dụng vùng lưu khoá được phần cứng bảo vệ của Android để lưu các thông tin không thuộc hệ thống khoá của kết, và cho phép mở khoá bằng vân tay như một tùy chọn của người dùng.
- **Hướng 3 – Mở rộng phạm vi định dạng của mô-đun siêu dữ liệu:** Bổ sung khả năng xoá siêu dữ liệu cho các định dạng ảnh và video khác, theo đúng nguyên tắc chỉ báo thành công khi thực sự dựng lại được tệp.
- **Hướng 4 – Xây dựng bộ bài giảng và bài thực hành kèm theo:** Biên soạn tài liệu hướng dẫn giảng viên, phiếu bài thực hành và bộ dữ liệu mẫu tương ứng với bảng ánh xạ chức năng, để đưa vào chương trình huấn luyện chính thức.
- **Hướng 5 – Đánh giá độc lập và mở rộng nền tảng:** Đề nghị đồng nghiệp và học viên rà soát mã nguồn; kiến trúc lõi dùng chung đã sẵn sàng cho nền tảng khác, việc mở rộng chủ yếu là bổ sung phần vỏ ứng dụng chứ không phải viết lại nghiệp vụ.

C. TÀI LIỆU THAM KHẢO VÀ TIÊU CHUẨN VIỆN DẪN

Các nguyên hàm mật mã và tham số mà tác giả lựa chọn đều dựa trên tiêu chuẩn hoặc khuyến nghị đã công bố, không phải do tác giả tự đặt ra.

- [1] RFC 9106 — Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Applications.
- [2] OWASP Password Storage Cheat Sheet — khuyến nghị tham số tối thiểu cho Argon2id (19 MiB bộ nhớ, 2 vòng lặp).
- [3] RFC 8439 — ChaCha20 and Poly1305 for IETF Protocols.
- [4] RFC 7748 — Elliptic Curves for Security (trao đổi khoá X25519).
- [5] RFC 8032 — Edwards-Curve Digital Signature Algorithm (chữ ký Ed25519).
- [6] A. Shamir, “How to share a secret”, Communications of the ACM, 1979.
- [7] BLAKE3 — đặc tả hàm băm mật mã và cơ chế dẫn xuất khoá theo ngữ cảnh.
- [8] Đặc tả định dạng age v1 — định dạng tệp mã hoá mở.
- [9] Tài liệu Android Developers — Storage Access Framework và Scoped Storage.
- [10] Đặc tả Exif 2.32 (CIPA DC-008) — cấu trúc siêu dữ liệu trong tệp ảnh.

D. PHỤ LỤC

Phụ lục A. Quy trình kiểm thử nghiệm thu trên thiết bị Android

Phụ lục này là quy trình nghiệm thu để xác nhận sản phẩm hoạt động đúng trên thiết bị thật. Mỗi bước có tiêu chí đạt rõ ràng để kết quả ghi nhận được khách quan, và cột cuối để trống cho người thực hiện điền kết quả.

Bảng 18. Quy trình kiểm thử nghiệm thu trên thiết bị Android

TT	Nội dung	Thao tác	Tiêu chí đạt	Kết quả
1	Cài đặt	Cài tệp APK và mở ứng dụng	Ứng dụng khởi động, hiển thị màn hình chính bằng tiếng Việt	
2	Không có quyền mạng	Xem mục Quyền ứng dụng trong Cài đặt hệ thống	Không có quyền truy cập mạng nào được liệt kê	
3	Tạo kết	Tạo kết mới, đặt mật khẩu	Tệp kết được tạo, ứng dụng báo thành công	
4	Thêm và trích xuất tệp	Thêm một tệp, khoá kết, mở lại, trích xuất	Tệp trích xuất giống hệt tệp gốc	
5	Từ chối mật khẩu sai	Mở kết bằng mật khẩu sai	Từ chối, thông báo rõ ràng, không tiết lộ thông tin khác	
6	Phát hiện sửa đổi	Sửa một byte của tệp kết rồi mở lại	Báo tệp bị hỏng hoặc bị sửa, không mở	
7	Khoá và mở khoá tệp đơn	Khoá một ảnh, mở lại bằng đúng mật khẩu	Ảnh khôi phục nguyên vẹn	
8	Ký và kiểm tra chữ ký	Tạo cặp khoá, ký tệp, kiểm tra chữ ký	Kiểm tra đạt; sau khi sửa tệp thì kiểm tra không đạt	
9	Vân tay tệp	Lấy vân tay cùng một tệp trên hai thiết bị	Hai giá trị vân tay trùng nhau	
10	Chia và khôi phục khoá	Chia bí mật 3 mảnh cần 2, khôi phục bằng	Khôi phục đúng; dùng 1 mảnh thì không	

		2 mảnh	khôi phục được	
11	Giấu tin và phát hiện	Giấu tệp vào ảnh, rồi dùng chức năng phát hiện	Trích xuất đúng tệp; chức năng phát hiện ghi nhận dấu hiệu	
12	Xem siêu dữ liệu ảnh	Chọn ảnh chụp bằng điện thoại rồi bấm Xem	Liệt kê các thẻ; ảnh có định vị thì thấy nhóm tọa độ	
13	Xoá siêu dữ liệu ảnh	Xoá siêu dữ liệu ảnh đó rồi xem lại bản đã xoá	Bản sạch không còn thẻ; ảnh gốc nguyên vẹn; ảnh vẫn mở xem được	
14	Thuỷ vân chống giả mạo	Đóng dấu một ảnh, sửa một vùng, kiểm tra lại	Phát hiện ảnh đã bị sửa và chỉ ra vùng bị can thiệp	
15	Tương thích liên nền tảng	Mở tệp kết tạo trên máy tính bằng ứng dụng di động	Mở được bằng đúng mật khẩu	

Đề nghị ghi lại kết quả từng bước kèm ảnh chụp màn hình để bổ sung vào hồ sơ.

Phụ lục B. Hình ảnh bổ sung từ thiết bị thật

Các hình dưới đây được chụp trong quá trình nghiệm thu tại Phụ lục A. Hồ sơ để trống thay vì dùng ảnh mô phỏng, nhằm bảo đảm mọi hình ảnh trong hồ sơ đều là ảnh thật.

[CHỖ DÀNH CHO HÌNH — Hình PL-1]

Ảnh chụp màn hình ứng dụng đang chạy trên điện thoại Android (màn hình chính)

Hình PL-1 (tác giả bổ sung sau khi chạy trên thiết bị thật)

[CHỖ DÀNH CHO HÌNH — Hình PL-2]

Ảnh chụp mục Quyền ứng dụng trong Cài đặt hệ thống, cho thấy ứng dụng không có quyền truy cập

mạng

Hình PL-2 (tác giả bổ sung sau khi chạy trên thiết bị thật)

[CHỖ DÀNH CHO HÌNH — Hình PL-3]

Ảnh chụp kết quả xem siêu dữ liệu của một ảnh chụp bằng điện thoại

Hình PL-3 (tác giả bổ sung sau khi chạy trên thiết bị thật)

....., ngày tháng năm 202...

XÁC NHẬN CỦA ĐƠN VỊ

(Ký, đóng dấu)

TÁC GIẢ SÁNG KIẾN

(Ký, ghi rõ họ tên)